

CPRE 4310

M01 Homework

Assignments will be submitted in PDF format via Canvas.

Please submit your homework online through Canvas. Late homework will not be accepted.

Important: Your submission must be in .pdf format ONLY!

You are not allowed to use AI tools to answer any of the HW questions

1. What is the difference between a threat, vulnerability, and risk?

A threat is a potential security harm to an asset. A vulnerability is a situation where corruption, leaks, or unavailability occurs to an asset. A risk is the potential for a loss or damage when a threat exploits a vulnerability.

For example, a vulnerability exposes an organization to potential threats. A threat is a malicious or negative event that takes advantage of the vulnerability of the organization. Then, a risk is the potential for loss and/or damage when a threat takes place.

2. Consider an automated teller machine (ATM) in which users provide a personal identification number (PIN) and a card for account access.
 - a. Give examples of confidentiality, integrity, and availability requirements for the system (ATM, Card, Pin) and, in each case, indicate the degree of importance (High, Medium, Low) of the requirement.

	Confidentiality	Integrity	Availability
ATM	A user's bank balance details and transaction history should remain secure and outside the reach of unauthorized access. (High)	Data such as the transaction history and transfers should be recorded and shown accurately. (High)	ATM should only be down for maintenance during off-peak hours. (Medium)
Card	The card number should only be known by the user and his chip/magnetic strip must be kept private. (High)	Data on the chip/magnetic strip of the card should not be altered by any third person or threat actor. (Medium)	The card should be durable enough to survive a few years and must handle the wear and tear of being put into and pulled out of the machine without damaging the chip or magnetic strip on it. (High)
Pin	Pin code should never be seen/known by other users. (High)	Pin must be verified by the ATM to ensure it is the same as the user set it initially and was not tampered with. (High)	The pin used by the user should be able to be input by the user easily using the ATM and must be responsive. (Medium)

- b. For the following scenarios, please indicate which security property (confidentiality, integrity, and availability, non-repudiation) is affected, and suggest how can we fix this:
- The ATM reads the Card data and Pin, then sends them as clear text on the network.
Confidentiality is affected. In order to fix this we can send the data from card and pin using stronger encryption instead of clear text.
 - The ATM allows user to increase/decrease his account monetary values (without actually adding/deducting money to/from his account), and user can claim that he/she was not responsible for this.
Integrity and non-repudiation is affected. In order to fix these issues, we can disallow users from modifying their account monetary values and track all other changes made to or in the account to ensure we are aware who is responsible.
 - The network connection between the ATM and the bank was down, and still the ATM allowed the users to perform their transactions.
Integrity and availability is affected. In order to fix these issues, the ATM needs to have network access to the bank to validate the information being keyed in by the users. The ATM should enforce authorization (with the bank) for the transactions being performed by the users and implement some form of redundancy protocols for when the network goes down to maintain availability for the users.

3. Consider the following general code for allowing access to a resource:

```
DWORD dwRet = IsAccessAllowed(...);
if (dwRet == ERROR) {
    // Security check failed.
    // Inform user that access is denied.
} else {
    // Security check OK.
}
```

- a. Explain the security flaw in this program.
The above code allows access to a resource as long as dwRet is not an error. This is a clear flaw because there may be warnings, access denied, connection error or even invalid requests that are returned by dwRet that the above code does not check for.
- b. Rewrite the code to avoid the flaw (Hint: Consider the design principle of fail-safe defaults.)

```
DWORD dwRet = IsAccessAllowed(...);

if (dwRet == ACCESS_GRANTED){

    // Security check OK.

} else {

    // Security check failed.

    // Inform user that access is denied.

}
```